INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC 103 Assignment

Phishing Simulation Metrics and Quantitative Risk Analysis

BY

MIRACLE NWADIARU

C11/26/CGRCE/17587

Note: The Excel sheet showing formulas and calculation **can be found here**

Comprehensive Executive Briefing: Phishing Risk Assessment

To: Board of Directors, CISO and CFO

From: GRC Risk Analysis Team

Date: 30 October 2026

Subject: Phishing Risk Assessment and Recommended Security Improvements

1. Executive Summary

The results of the three phishing simulations show that employees remain vulnerable to phishing attacks, particularly those designed to obtain login credentials. Campaign B, the IT System Password Reset simulation, recorded the highest credential submission rate at 30%. Campaign A recorded 18%, while Campaign C recorded 15%.

If Campaign B's results were replicated across the organization's 2,000 employees, approximately 600 employees could submit their credentials. Based on the assumed 25% probability of a major breach following credential theft, this could result in 150 expected breach events, with a potential financial exposure of $652.5 million under the lab's assumptions.

These findings highlight the need to strengthen the organization's security controls. Implementing multi-factor authentication (MFA), improving employee awareness, and strengthening email security should be the main priorities. The financial figures are projections based on the lab's assumptions and should not be treated as confirmed losses.

2. Findings

Metric	Campaign A: HR Bonus	Campaign B: IT Password Reset	Campaign C: CEO Urgent Document Review
Emails sent	100	250	80
Emails opened	82	200	72
Clicks	47	150	60

Credential submissions	18	75	12
Data entry points	5	25	8
Open rate	82%	80%	90%
Click-through rate	47%	60%	75%
Credential submission rate	18%	30%	15%
Data entry rate	5%	10%	10%
Open-to-click conversion	57.32%	75.00%	83.33%
Click-to-credential conversion	38.30%	50.00%	20.00%

Interpretation

- **Campaign A: HR Bonus:** Eighteen per cent of recipients submitted credentials. This indicates a need for awareness training on unexpected HR-related offers and requests.
- **Campaign B: IT Password Reset:** This campaign had the highest credential submission rate at 30%. Half of those who clicked submitted credentials, making this the highest-priority campaign for risk reduction.
- **Campaign C: CEO Urgent Document Review:** The campaign had the highest open rate at 90% and click-through rate at 75%. Its open-to-click conversion was 83.33%. Although its credential submission rate was lower than the other campaigns, the high click-through rate suggests that urgent or authority-based messages warrant additional attention.

The overall data entry rates were 5%, 10%, and 10% for Campaigns A, B, and C, respectively. Data entry points should be interpreted according to the laboratory's measurement definitions; they should not automatically be treated as additional unique compromised accounts.

3. Risk Assessment Matrix

The following matrix retains the laboratory's qualitative priority assignments and uses corrected financial estimates. For comparability, the exposure model applies the same assumptions to all three campaigns.

Scenario assumptions:

- Workforce: 2,000 employees.
- Cost per major breach: $4.35 million.
- Assumed probability of a major breach following credential theft: 25%.

Campaign	Credential submission rate	Projected credential submitters	Modeled breach events	Modeled financial exposure	Risk rating	Priority
Campaign A: HR Bonus	18%	360	90	$391.5 million	Medium–High	2
Campaign B: IT Password Reset	30%	600	150	$652.5 million	Critical	1
Campaign C: CEO Urgent Document Review	15%	300	75	$326.25 million	High	3

Risk priorities and justification

- **Priority 1 - Campaign B:** The 30% credential submission rate and highest modeled exposure make password-reset phishing the immediate priority. MFA deployment and a review of password-reset procedures should be prioritized.
- **Priority 2 - Campaign A:** The 18% credential submission rate warrants targeted training on unexpected HR offers and requests. Employees should be encouraged to verify such communications through trusted channels.
- **Priority 3 - Campaign C:** The high click-through rate suggests employees may respond to urgent messages from apparent senior leaders. Executive impersonation awareness, email filtering, and clear procedures for verifying urgent requests are recommended.

The qualitative ratings are retained from the laboratory's original framework. They should be reviewed against GlobalTech's formal risk-rating criteria before being adopted as final organizational ratings.

Important financial limitation

These figures represent modeled exposure under the supplied assumptions. They do not establish that 90, 150, or 75 actual breaches will occur. Credential

submissions do not necessarily result in separate breaches, and the independence of individual compromise events has not been demonstrated.

The exposure figures should not be labelled annual loss expectancy (ALE) without a defensible annual event-frequency assumption. They should instead be described as scenario-based exposure estimates.

4. Statistical Analysis and Confidence Intervals

Confidence intervals help communicate uncertainty in the observed credential submission rates. The calculations use the normal approximation for a proportion:

95% confidence interval = p ± 1.96 × √[p(1 − p) / n]

Here, *p* is the observed credential submission proportion and *n* is the number of emails sent.

Campaign	Observed credential submission rate	Sample size	Approximate 95% confidence interval
Campaign A: HR Bonus	18%	100	10.47%–25.53%
Campaign B — IT Password Reset	30	250	24.3%–35.7%

The intervals indicate uncertainty around the observed rates, assuming the sampling model is appropriate. They do not measure the probability of a future breach or the accuracy of the financial exposure estimates.

Sampling limitations

The campaigns targeted different groups and used different message themes. The samples may therefore differ in their roles, access privileges, email usage, or exposure to particular requests. The results should not automatically be treated as representative of the entire workforce.

Pooling the three samples gives:

Total credential submissions ÷ total emails sent = 105 ÷ 430 = 24.42%.

This pooled figure describes the combined campaign samples. It is not necessarily a reliable workforce-wide rate because the target groups and campaign conditions differ.

The confidence intervals also rely on assumptions about the observations and sampling process. If employees within a target group have similar behaviors, or if participation and targeting were not representative, the actual uncertainty may be greater than these intervals suggest.

5. Security Control Recommendation

The following table compares the proposed control costs with the assumptions and estimates available in the laboratory brief. Where effectiveness is not adequately specified, the financial benefit and ROI are identified as unquantified rather than presented as established results.

Control	Estimated Cost	Priority
Multi-factor authentication (MFA)	$90,000	1
Security awareness training	$100,000	2
Advanced email filtering	$50,000	3

6. Recommended Actions

Immediate actions

1. **Prioritise MFA deployment.** Begin with privileged accounts, sensitive systems, and accounts exposed to credential-based attacks.
2. **Review password-reset procedures.** Ensure employees can verify legitimate IT requests using trusted channels.
3. **Strengthen email filtering.** Review the organization's ability to detect and block suspicious messages, links, and impersonation attempts.
4. **Deliver targeted awareness training.** Focus on password-reset requests, unexpected HR offers, and urgent executive communications.
5. **Provide targeted executive-impersonation guidance.** Reinforce verification and escalation procedures for unusual or urgent requests.

Medium- and long-term actions

1. Implement continuous monitoring to identify suspicious account activity and potential misuse of credentials.
2. Assess whether behavior analytics can improve detection and response, and define measurable performance indicators.
3. Conduct recurring phishing simulations to measure changes in click-through and credential submission rates over time.
4. Compare future simulation results with these baseline measurements, taking account of differences in campaign design and target groups.
5. Validate control effectiveness and financial assumptions before calculating a combined portfolio ROI or presenting projected savings to management.

7. Conclusion

The phishing simulations identify meaningful exposure to credential-based attacks. Campaign B should receive the highest priority because it recorded the greatest credential submission rate and the largest modeled financial exposure. Campaign C also warrants attention because of its high click-through rate, while Campaign A indicates that HR-themed messages remain an effective phishing approach.

MFA, email filtering, and targeted awareness training are appropriate initial control priorities. Monitoring, behaviour analytics, and recurring simulations can support longer-term improvement.

The financial model indicates that the assumed cost of a major breach is substantially higher than the proposed security investment. However, the modeled exposure and projected control returns depend on assumptions that have not been independently validated. Management should use the results to guide prioritisation and further assessment, not as guaranteed loss forecasts or guaranteed savings.

The next step is to validate the assumptions, implement the priority controls, and use subsequent simulation results and incident data to assess whether the organisation's exposure is actually declining.